

Use Case for Sprint 6: Users with Authentication and Sessions

Primary Actor: User

Goal: The user can authenticate and maintain an active session to access only their own documents and searches.

Preconditions:

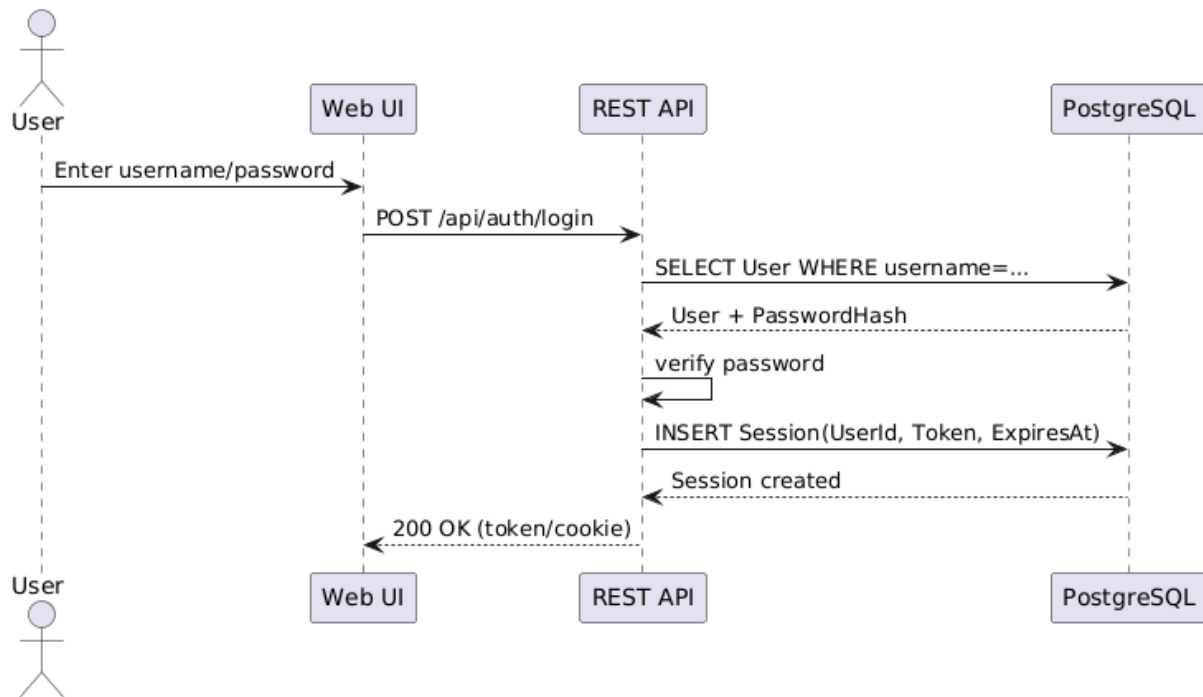
- User account exists (registered or seeded).
- REST API is reachable.

Postconditions (success):

- A valid session exists (session token/cookie issued).
- Subsequent requests are authorized and associated with the user identity.

Main Flow (happy path):

1. User opens Web UI.
2. User enters username/password.
3. Web UI sends POST /api/auth/login.
4. REST API validates credentials against the user store (PostgreSQL).
5. REST API creates a session record (Session entity) and issues a session token.
6. Web UI stores token (cookie or Authorization header).
7. User calls protected endpoints (upload, list, search).
8. REST API authorizes requests using the session token and determines UserId.



Alternative Flows:

- Invalid credentials: return 401, no session created.
- Session expired: return 401; user must login again.
- Logout: POST /api/auth/logout invalidates session.

Security / Constraints:

- Session token is random and unguessable.
- Session has expiration (ExpiresAt).
- All document operations enforce “user owns document”.

2) Domain Model Documentation (Users + Sessions)

New Entities

User

- Id : Guid
- Username : string (unique)
- PasswordHash : string
- CreatedAt : DateTimeOffset

Session

- Id : Guid
- UserId : Guid (FK)
- Token : string
- CreatedAt : DateTimeOffset
- ExpiresAt : DateTimeOffset